

## ACTIVITY PACK

# Activity 2: Security Checklist

Activity 2 - Prompt Injection and the PDPA Breach Decision

|             |                                      |
|-------------|--------------------------------------|
| Course      | AI Security for Autonomous AI Agents |
| Course code | TGS-2025060473                       |
| Version     | 3.0   20 August 2026                 |

Tertiary Infotech Pte Ltd | UEN 20120096W

## Security Checklist

# Activity 2 - Prompt Injection and PDPA Checklist

### Break the attack chain

- ☐ Untrusted content is labelled with provenance before it enters model context.
- ☐ OCR, attachments, retrieved chunks, email quotes and context files pass through the same trust policy.
- ☐ A tool-free reader or summariser handles high-risk external content.
- ☐ Retrieval is bound to the current claim and customer; the agent cannot enumerate adjacent records.
- ☐ Tool schemas enforce permitted record IDs, fields, recipients and action types.
- ☐ External recipients and outbound domains are allowlisted; free-form egress is blocked.
- ☐ High-impact or unusual actions require a code-defined human approval checkpoint.
- ☐ Rate, sequence and anomaly controls detect repeated lookups and recipient overrides.

### Test the guardrails

- ☐ Direct, indirect, cross-modal, split-source and context-file variants are tested.
- ☐ Attack success rate is reported by attack family, not only as an average.
- ☐ Clean-task refusal and false-positive rates are measured with the same release.
- ☐ Tests run with synthetic data and dummy tools; production personal data is excluded.
- ☐ Model, prompt, tool, corpus, skill/plugin and policy versions are recorded with results.

### PDPA response

- ☐ Prompts, outputs, retrieval content, tool arguments and logs are in the personal-data inventory.
- ☐ The DPO assesses significant harm and scale as separate notification limbs.
- ☐ Evidence identifies affected fields, individuals, recipients, duration and containment actions.
- ☐ The organisation can meet the applicable PDPC and affected-individual notification duties.
- ☐ Retention is long enough for investigation but no longer than the documented purpose requires.